

République du Cameroun
 Paix-Travail-Patrie

 Ministère de l'Enseignement Supérieur

 Université de Garoua

 Faculté des Sciences

 Division des Affaires Académiques, de la
 Scolarité et de la Recherche

Republic of Cameroon
 Peace-Work-Fatherland

 Ministry of Higher Education

 Université of Garoua

 Faculté of Science

 Division of Academic Affairs, Student's
 Admission and Research



UE : ANALYSE FORENSIQUE ET GESTION DES INCIDENTS

TPE: AUTOPSY : ANALYSE SYSTÉMATIQUE

N°	Noms et prénoms	Matricule	NIVEAU
1	NAMAWI JEAN YVES	CM-UGa-24FS0784	MASTER II

Exercice. 6.1 — Analyse du registre

Commandes à utiliser

bash

rip.pl -r SOFTWARE -p run

rip.pl -r SOFTWARE -p runonce

rip.pl -r NTUSER.DAT -p run

rip.pl -r NTUSER.DAT -p runonce

rip.pl -r SYSTEM -p timezone

rip.pl -r SAM -p samparse

Ce qu'il faut documenter

- Clés Run présentes :
 - HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Run
 - HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\RunOnce
 - HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run
 - HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\RunOnce
 - éventuellement ...\Policies\Explorer\Run si présent.
- Comptes locaux dans la SAM :
 - relever les comptes administrateurs, utilisateurs standards et comptes désactivés depuis la sortie samparse.
- Fuseau horaire configuré :
 - extraire la clé ControlSet00x\Control\TimeZoneInformation et noter le nom du fuseau.

Forme de rendu

- Clé complète.
- Valeur associée.
- Interprétation.
- Indice de compromission éventuel.

Exemple de rédaction :

- HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Run : lancement automatique au logon.
- HKEY_LOCAL_MACHINE\SAM\Domains\Account\Users\... : compte local extrait via samparse.

- HKEY_LOCAL_MACHINE\SYSTEM\ControlSet001\Control\TimeZoneInformation : fuseau horaire du système.

Exercice 6.2 — Timeline NTFS

Commandes à utiliser

bash

fls -r -m / -o <offset> srv-web-01.dd > bodyfile.txt

mactime -b bodyfile.txt > timeline.txt

Ou en ciblant la plage temporelle après filtrage :

bash

mactime -b bodyfile.txt | grep "2026-04-12"

Le principe est bien celui décrit par The Sleuth Kit : fls produit le bodyfile et mactime génère la timeline exploitable.

Comment traiter la plage

Filtre ensuite sur :

- 2026-04-12 02:00 UTC
- 2026-04-12 06:00 UTC

Les 5 événements les plus suspects

Sans ton bodyfile réel, voici les types d'événements à retenir et leur mapping MITRE probable :

1. Création d'un exécutable ou script dans un répertoire temporaire
 - MITRE : T1059 ou T1204 selon le contexte.
2. Exécution d'un binaire depuis un chemin inhabituel
 - MITRE : T1059, T1036 ou T1218.
3. Connexion sortante inhabituelle corrélée à un dropper
 - MITRE : T1071.001.
4. Modification de fichiers système ou webroot
 - MITRE : T1105, T1565 ou T1505.
5. Suppression/troncature de logs ou artefacts
 - MITRE : T1070.001.

Format de rendu attendu

Timestamp UTC	Fichier / artefact	Événement	Suspicion	TTP MITRE
2026-04-12 03:17	/var/log/...	suppression / rotation	effacement de traces	T1070.001

Timestamp UTC	Fichier / artefact	Événement	Suspicion	TTP MITRE
2026-04-12 03:21	/tmp/...	exécution suspecte	probable dropper	T1059
etc.				

Exercice. 6.3 — Persistence Linux

Pistes de recherche

Vérifie systématiquement :

- cron :
 - /etc/crontab
 - /etc/cron.d/
 - /var/spool/cron/
- systemd :
 - /etc/systemd/system/
 - /usr/lib/systemd/system/
 - timers .timer
- LD_PRELOAD :
 - /etc/ld.so.preload
- authorized_keys :
 - /root/.ssh/authorized_keys
 - /home/*/.ssh/authorized_keys
- bashrc :
 - /root/.bashrc
 - /home/*/.bashrc
 - profile, bash_profile, zshrc si présents

Les timers systemd et cron sont des vecteurs classiques de persistance, et la surveillance de fichiers / changements de registre ou configuration est une pratique de détection courante.[\[blog.stephane-robert\]](#)

Ce qu'il faut documenter

Pour chaque mécanisme trouvé :

- chemin complet ;
- contenu exact ou résumé ;
- utilisateur concerné ;
- finalité probable ;

- niveau de suspicion.

Exemple de rédaction

- `/etc/cron.d/update-job` : exécution périodique d'un script inconnu, persistance probable.
- `/etc/systemd/system/backup.service` : service lancé au boot, à vérifier.
- `/etc/ld.so.preload` : chargement d'une bibliothèque suspecte, très fort indicateur de compromission.
- `/root/.ssh/authorized_keys` : ajout d'une clé inconnue, persistance distante.
- `/home/user/.bashrc` : appel vers un script externe, persistance à l'ouverture de session

Exercice 7.1 — Analyse mémoire

(a) Processus actifs

Commence par lister les processus du dump mémoire et relève ceux qui existaient au moment de la compromission. Les processus typiquement importants sont `pslist`, `pstree` et `psscan`, puis la comparaison entre les vues permet d'identifier des processus invisibles ou injectés.

Dans ta copie, note pour chaque processus : nom, PID, PPID, heure de création, session, et comportement suspect éventuel.

(b) Connexions réseau

Liste les connexions réseau établies pour identifier les destinations externes, les ports et l'état de chaque socket. Les connexions suspectes sont souvent celles vers une IP non reconnue, vers un port non standard, ou correspondant à un trafic périodique de type beacon.

Dans le rendu, il faut associer chaque connexion à un PID et à un processus hôte, afin de relier réseau et exécution.

(c) Zones suspectes avec malfind

Les zones suspectes sont celles qui montrent des pages mémoire exécutable avec des permissions anormales, du code injecté, ou une image mémoire incohérente avec le binaire disque.

Documente chaque zone par l'adresse virtuelle, le PID, le nom du processus, l'état des pages, et l'indice de suspicion, par exemple injection, hollowing, ou shellcode.

(d) Processus caché / DKOM

Pour un processus caché, compare les résultats de la liste normale des processus avec ceux obtenus par la recherche brute dans la mémoire. Si un PID apparaît dans la vue brute mais pas dans la liste active, cela suggère une dissimulation DKOM.

Dans le compte rendu, indique le PID caché, le processus associé, et explique que cette divergence est un fort indicateur de rootkit.

Exercice 7.2 — Analyse réseau

(a) IP de C2

Dans Wireshark et Zeek, l'IP de C2 est généralement celle qui reçoit des connexions régulières ou qui initie des sessions de contrôle répétitives, souvent avec peu de volume mais à intervalles stables.

L'IP à retenir est celle qui ressort dans conn.log, dans les flux TCP répétés, ou dans les conversations les plus anormales.

(b) Protocole de communication

Le protocole peut être HTTP, HTTPS, DNS, FTP ou un protocole applicatif personnalisé. La qualification doit se baser sur le port, le type de requêtes, les en-têtes, et la forme des échanges observés.

Si le trafic est chiffré, il faut préciser qu'on observe surtout les métadonnées, pas le contenu, et s'appuyer sur la périodicité et la structure des connexions.

(c) Données exfiltrées

Les données exfiltrées sont à identifier dans les téléchargements, les POST HTTP, les transferts de fichiers, ou les objets exportés de la capture. Zeek peut aider à repérer les flux longs, les volumes anormaux et les fichiers extraits.

Dans la copie, mentionne la nature des données, leur volume, la direction du flux et le protocole utilisé.

(d) Durée totale de l'activité C2

La durée totale correspond à l'intervalle entre le premier et le dernier échange de commande et contrôle observé dans la capture.

Tu dois la présenter en heures, minutes et secondes, à partir des timestamps du premier et du dernier flux C2.

Exercice 7.3 — CloudTrail

Après un CreateAccessKey depuis une IP TOR, les **4 prochaines actions d'investigation** doivent être :

1. **Vérifier l'identité et le contexte de l'événement** : compte, utilisateur IAM, région, user-agent, source IP, heure exacte et éventuels échecs/succès voisins.
2. **Lister les actions IAM corrélées autour de l'événement** : AttachUserPolicy, PutUserPolicy, UpdateLoginProfile, CreatePolicyVersion, AddUserToGroup, AssumeRole, etc..
3. **Contrôler l'usage de la nouvelle clé** : rechercher ListBuckets, GetObject, DescribeInstances, sts:AssumeRole, ou toute action de découverte/exfiltration après la création de clé.

4. **Faire l'inventaire des logs associés à la compromission** : CloudTrail, VPC Flow Logs, logs d'authentification IAM, AWS Config, CloudWatch, S3 access logs si les données sont dans S3.

Logs à consulter

- **CloudTrail Event history** et trail S3 pour les actions API.
- **VPC Flow Logs** pour les connexions réseau suspectes depuis l'instance ou vers l'extérieur.
- **CloudWatch Logs** si des alarmes ou journaux applicatifs sont centralisés.
- **AWS Config** pour voir les changements de configuration de sécurité.
- **S3 Access Logs** si l'exfiltration cible des buckets.

Formulation courte à rendre

Pour l'analyse mémoire, il faut lister les processus actifs, leurs connexions réseau, les zones injectées détectées par malfind, puis vérifier si un processus est caché par comparaison entre liste normale et scan brut de mémoire.

Pour l'analyse réseau, il faut identifier l'IP C2, le protocole, les données exfiltrées et la durée totale de l'activité en corrélant Wireshark et Zeek.

Pour CloudTrail, une création de clé API depuis TOR impose de vérifier les actions IAM corrélées, l'usage de la clé, puis de consulter CloudTrail, VPC Flow Logs, CloudWatch, AWS Config et les logs S3 si nécessaire.